INCIDENT RESPONSE PLAYBOOK

Project: Incident Response Playbook

Prepared by: Sejal Devi

Project Type: Cybersecurity

Objective: To create a structured procedure for identifying, analyzing, containing, and recovering from cybersecurity incidents.

1. Introduction

An Incident Response Playbook is a documented set of procedures that helps an organization respond to cybersecurity incidents in a systematic and effective manner. It helps reduce damage, protect sensitive information, and restore normal operations.

2. Objectives

- Identify suspicious activities and potential security incidents.
- Analyze alerts and determine their severity.
- Contain incidents to prevent further damage.
- Remove the cause of an incident.
- Recover affected systems securely.
- Document findings and improve future security.

3. Tools

- Windows Notepad: Documentation.

- Windows Event Viewer: Reviewing available system events.

- VirusTotal: Checking suspicious file hashes or URLs.

- Splunk: Example of a Security Information and Event Management (SIEM) platform.

- Microsoft Defender: Reviewing security alerts and scanning for threats.

4. Incident Response Lifecycle

1. Preparation

2. Detection and Analysis

3. Containment

4. Eradication

5. Recovery

6. Lessons Learned

5. Simulated Security Incident

Scenario: A user receives a suspicious email containing a link that may lead to a phishing website.

Initial Alert: The user reports the email to the security team.

Potential Risks: Credential theft, unauthorized account access, and exposure of sensitive information.

Incident Status: Simulated for educational purposes. No real attack was conducted.

6. Detection and Analysis

- Record the date and time the incident was reported.
- Preserve the suspicious email and its headers where possible.
- Examine the sender, URL, and email content without opening suspicious links.
- Check available security alerts and relevant logs.
- Determine the scope and severity of the incident.
- Record all findings and actions taken.

7. Containment

- Ask the user not to interact further with the suspicious email.
- Report or quarantine the message using approved organizational procedures.
- If credentials may have been exposed, secure the affected account and reset credentials through the official process.
- Revoke suspicious active sessions when appropriate.
- Escalate the incident to the responsible security team.

8. Eradication

- Remove or quarantine confirmed malicious messages using approved tools.
- Scan affected devices with trusted security software.
- Remove confirmed threats according to organizational procedures.
- Fix the weaknesses that allowed the incident to occur.

9. Recovery

- Restore affected systems or accounts to a secure state.
- Confirm that security scans and relevant checks are successful.
- Monitor for repeated suspicious activity.
- Inform the appropriate team when recovery is complete.

10. Incident Documentation

Record the following information:

- Incident ID
- Date and time reported
- Incident description
- Affected users or systems
- Evidence collected
- Severity and impact
- Containment and recovery actions
- Final status

11. Lessons Learned

- Provide phishing awareness training.
- Encourage users to report suspicious emails promptly.
- Improve email filtering and account security.

- Enable multifactor authentication where available.

- Review the response process and update the playbook.

12. Conclusion

This project demonstrates a structured approach to incident response using a simulated phishing incident. It covers detection, analysis, containment, eradication, recovery, documentation, and lessons learned. The playbook can be adapted to support an organization's incident response procedures.

13. Practical Investigation: Windows Security Logs

Evidence 1: Failed Logon Event

- Log Source: Windows Security

- Event ID: 4625

- Observed Result: Failed logon recorded

- Logon Type: 2 (Interactive)

- SubStatus: 0xC000006A

- Workstation: TUF15

Analysis

The Windows Security log contains a failed logon event. The SubStatus value 0xC000006A commonly corresponds to an incorrect password. The interactive logon type indicates an attempt associated with local interactive sign-in.

This event alone does not establish malicious activity. Further investigation would consider the event timestamp, account involved, related logon events, and whether the activity was expected.

Recommended Response

1. Verify whether the failed logon was expected.
2. Review nearby authentication events for repeated failures or unusual patterns.
3. If suspicious activity is identified, follow the organization's account-protection and incident-escalation procedures.
4. Preserve relevant logs and document the investigation.
5. Monitor for additional suspicious authentication activity.

Evidence Limitation

The available event details do not independently identify the person who initiated the attempt or prove that an attack occurred.

Conclusion

This exercise demonstrates how Windows Security logs can support authentication investigations and evidence-based incident response.

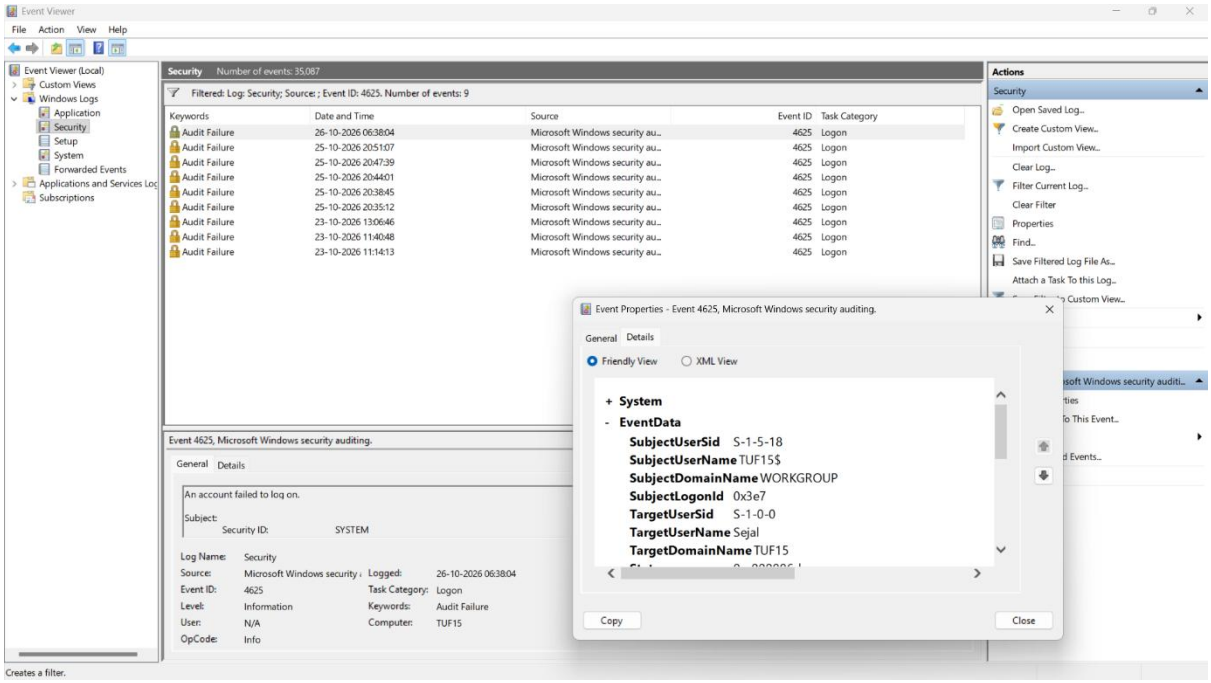


Figure 1: Windows Security log showing failed logon events (Event ID 4625).

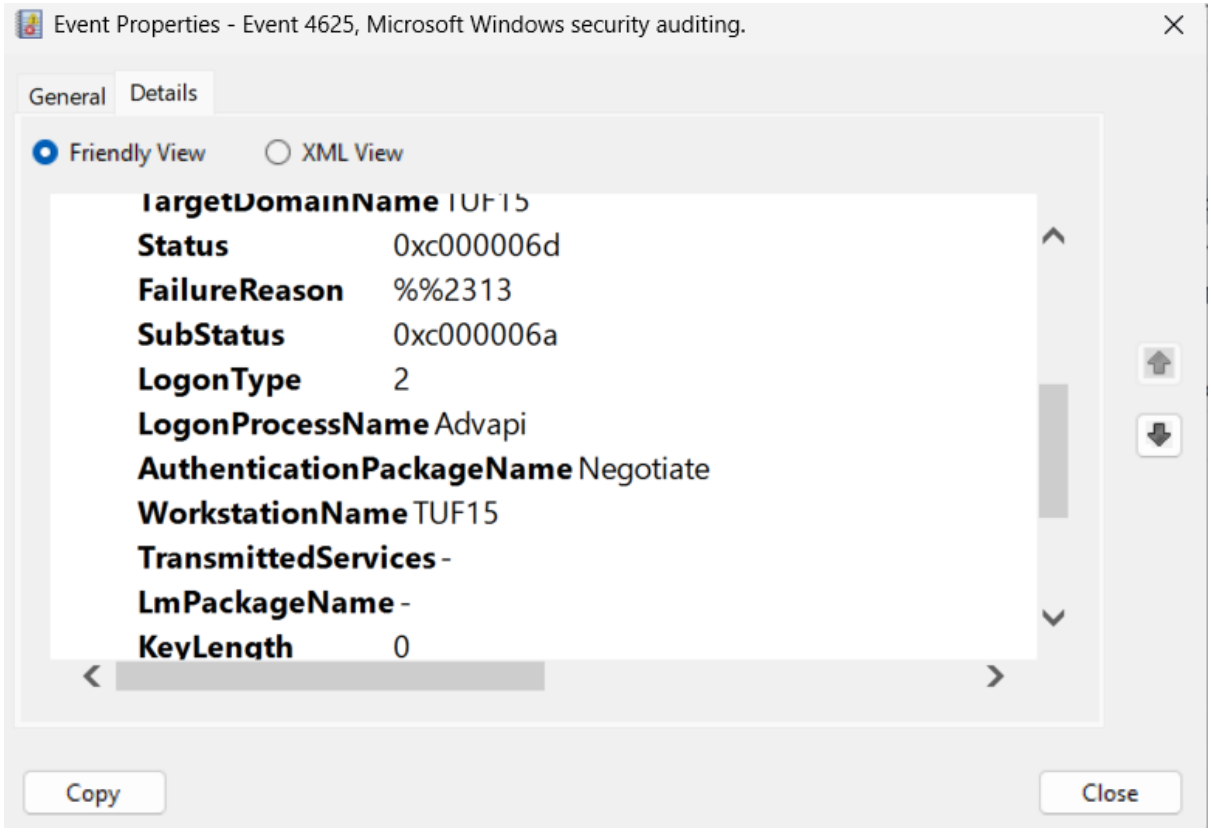


Figure 2: Details of a selected failed logon event, including the logon type and status information.

14. Practical Investigation: Successful Logon Analysis

Evidence 2: Successful Service Logon

- Log Source: Windows Security
- Event ID: 4624
- Logon Type: 5 (Service)
- Target User: SYSTEM
- Observed Result: Successful logon event recorded

Analysis

The Windows Security log contains successful logon events. The inspected event uses Logon Type 5 and identifies the SYSTEM account. This is consistent with Windows service activity.

A successful service logon is not inherently suspicious. Its legitimacy should be assessed using the service, timestamp, associated account, and surrounding events.

Recommended Response

1. Confirm that the event corresponds to expected Windows service activity.
2. Correlate the timestamp with relevant system and security events.
3. Investigate unexpected service accounts or unusual authentication patterns.
4. Preserve relevant log evidence and document the findings.

Conclusion

Comparing successful and failed logon events helps incident responders establish context before deciding whether further investigation is necessary.

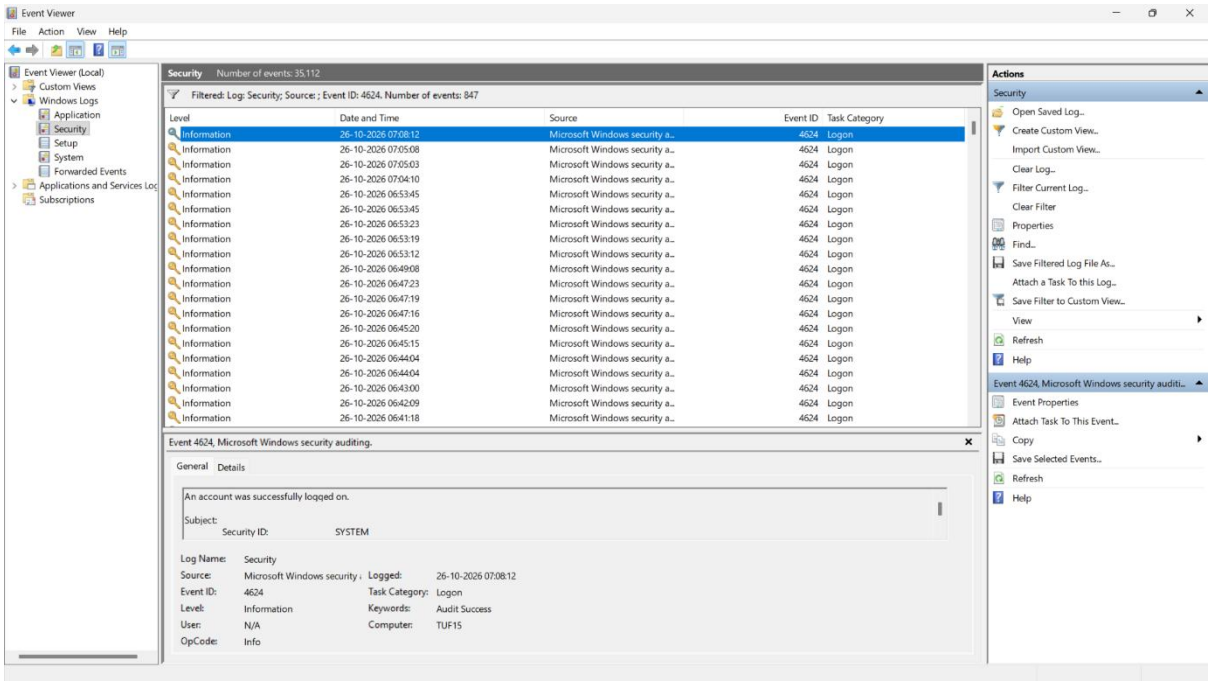


Figure 3: Windows Security log showing successful logon events (Event ID 4624).

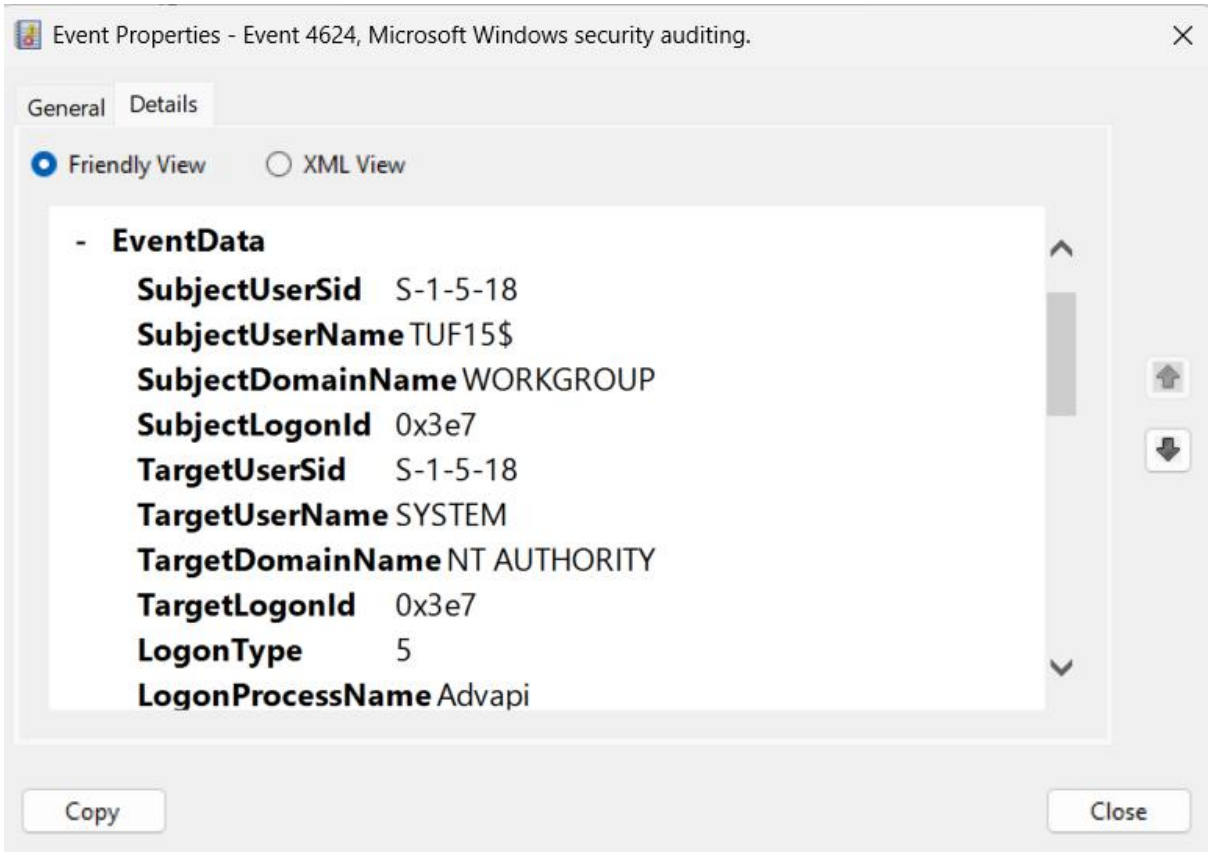


Figure 4: : Details of a selected successful logon event, including the logon type and status information.

15. Incident Severity Classification

Severity 1 — Critical

Examples: Confirmed ransomware, active compromise of critical systems, or widespread data exfiltration.

Response:

1. Notify the incident response lead immediately.
2. Follow the organization's emergency containment procedure.
3. Protect evidence and coordinate recovery with authorized personnel.

Severity 2 — High

Examples: Strong evidence of account compromise, repeated suspicious authentication activity, or unauthorized access to sensitive systems.

Response:

1. Escalate promptly to the security team.
2. Investigate related authentication and system logs.
3. Apply approved containment measures when authorized.

Severity 3 — Medium

Examples: Unusual activity that requires investigation but has not been confirmed as malicious.

Response:

1. Review relevant logs and timestamps.
2. Correlate activity across available evidence.
3. Document findings and assign follow-up actions.

Severity 4 — Low

Examples: Isolated failed logons or routine warnings with no other suspicious indicators.

Response:

1. Record the event.
2. Check whether it matches expected activity.
3. Monitor for repetition or additional warning signs.

Severity Assessment Rule

Severity must be based on evidence, business impact, scope, and confidence—not on a single event ID alone. Escalate immediately if evidence suggests an active threat.

16. Incident Response Checklist

Phase 1: Identification

- [ ] Record the alert or event.
- [ ] Note the date, time, source, and affected account or system.

- [ ] Review relevant security logs.
- [ ] Determine whether additional investigation is required.

Phase 2: Analysis

- [ ] Examine related events and timestamps.
- [ ] Compare successful and failed authentication activity.
- [ ] Assess severity using available evidence.
- [ ] Document confirmed facts and uncertainties.

Phase 3: Containment

- [ ] Notify the authorized incident response contact.
- [ ] Follow approved containment procedures.
- [ ] Avoid deleting logs or destroying evidence.
- [ ] Record actions taken and their timestamps.

Phase 4: Eradication and Recovery

- [ ] Identify and address the confirmed root cause.
- [ ] Apply authorized remediation.
- [ ] Restore affected services safely.
- [ ] Verify that normal operation has resumed.

Phase 5: Lessons Learned

- [ ] Summarize the incident and its impact.
- [ ] Record the evidence reviewed.

- [ ] Identify improvements to security controls.

- [ ] Update the playbook where necessary.

Important: This checklist is a general educational template. Real incidents must be handled according to the organization's policies and authorized response procedures.

17. Sample Incident Investigation Report

Incident Title

Review of Windows Authentication Events

1. Objective

To inspect Windows Security logs, identify authentication events, and practice evidence-based incident analysis.

2. Environment

- Operating System: Windows

- Tool: Windows Event Viewer

- Log Source: Windows Security

- Investigation Type: Authentication log review

3. Evidence Collected

Evidence A — Failed Logon

- Event ID: 4625

- Logon Type: 2 (Interactive)

- SubStatus: 0xC000006A

- Result: A failed logon was recorded.

Evidence B — Successful Logon

- Event ID: 4624

- Logon Type: 5 (Service)

- Target User: SYSTEM

- Result: A successful service logon was recorded.

4. Analysis

The failed logon event contains a SubStatus value commonly associated with an incorrect password. The successful logon event is consistent with Windows service activity.

These events demonstrate how Windows records authentication activity. The available evidence does not establish that an attack occurred or that the events are causally related.

5. Initial Assessment

- Finding: Authentication events requiring contextual interpretation.

- Confirmed compromise: Not established.

- Severity: Undetermined pending further investigation.

- Business impact: Not established.

6. Recommended Follow-Up

1. Review event timestamps and relevant surrounding records.

2. Confirm whether the failed logon was expected.

3. Examine account and logon details where available.

4. Escalate if corroborating evidence indicates suspicious activity.

5. Preserve relevant logs and document conclusions.

7. Conclusion

This investigation provided practical experience filtering Windows Security logs, examining Event IDs 4625 and 4624, and documenting findings without assuming malicious activity from individual events.

8. Evidence References

- 02_Failed_Logon_Events.png

- 03_Failed_Logon_Details.png

- 04_Successful_Logon_Events.png

The evidence files should be stored in the project's Evidence folder.